

MERIDIAN HEALTH ANALYTICS, INC. — CONTROL MAPPING SPREADSHEET

Sample GRC portfolio artifact | Maps one control per row across NIST CSF 2.0, CIS Controls v8, ISO/IEC 27001:2022 Annex A, and SOC 2 (Trust Services Criteria)

Control Domain	Control Description	NIST CSF 2.0	CIS Controls v8	ISO/IEC 27001:2022 Annex A	SOC 2 TSC	Implementation Status	Owner
Asset Inventory	Maintain an accurate, continuously updated inventory of all enterprise hardware and software assets	ID.AM-01, ID.AM-02	CIS 1: Inventory & Control of Enterprise Assets; CIS 2: Inventory & Control of Software Assets	A.5.9 Inventory of information and other associated assets	CC6.1	Partial	IT Asset Manager
Data Classification	Classify data based on sensitivity (e.g., PHI, PII, confidential, public) and apply handling requirements accordingly	ID.AM-05, PR.DS-01	CIS 3: Data Protection	A.5.12 Classification of information; A.5.13 Labelling of information	CC6.1, CC6.7	Implemented	Data Governance Lead
Access Control / Least Privilege	Restrict logical and physical access to systems and data to authorized individuals based on the principle of least privilege	PR.AA-01, PR.AA-05	CIS 5: Account Management; CIS 6: Access Control Management	A.5.15 Access control; A.8.2 Privileged access rights	CC6.1, CC6.3	Partial	IAM Manager
Multi-Factor Authentication	Require multi-factor authentication for all remote access and administrative/privileged accounts	PR.AA-02	CIS 6.5: Require MFA for Administrative Access	A.8.5 Secure authentication	CC6.1, CC6.6	Implemented	IAM Manager
Encryption of Data at Rest	Encrypt sensitive data (including PHI) at rest using industry-standard algorithms and managed key infrastructure	PR.DS-01	CIS 3.11: Encrypt Sensitive Data at Rest	A.8.24 Use of cryptography	CC6.1, CC6.7	Partial — see Risk R-001	Data Governance Lead
Encryption of Data in Transit	Encrypt sensitive data in transit using TLS 1.2 or higher across all internal and external network communications	PR.DS-02	CIS 3.10: Encrypt Sensitive Data in Transit	A.8.24 Use of cryptography	CC6.1, CC6.7	Partial — see Risk R-012	Director of Engineering
Vulnerability Management	Establish a recurring process to identify, prioritize, and remediate vulnerabilities across the technology environment	ID.RA-01, PR.PS-02	CIS 7: Continuous Vulnerability Management	A.8.8 Management of technical vulnerabilities	CC7.1	Implemented	Security Operations Lead
Security Awareness Training	Provide role-based security awareness training to all workforce members on a recurring basis	PR.AT-01, PR.AT-02	CIS 14: Security Awareness & Skills Training	A.6.3 Information security awareness, education and training	CC1.4, CC2.2	Partial — see Risk R-013	Security Awareness Lead
Third-Party / Vendor Risk Management	Assess and monitor the security posture of vendors and service providers with access to sensitive data or systems	GV.SC-06, GV.SC-07	CIS 15: Service Provider Management	A.5.19 Information security in supplier relationships; A.5.20 Addressing security within supplier agreements	CC9.2	Partial — see Risk R-003, R-007	Vendor Risk Manager
Continuous Monitoring / Logging	Collect, retain, and monitor security event logs across critical systems to support detection and investigation	DE.CM-01, DE.CM-09	CIS 8: Audit Log Management	A.8.15 Logging; A.8.16 Monitoring activities	CC7.2	Implemented	Security Operations Lead
Incident Response Plan	Maintain and periodically test a documented incident response plan covering detection, containment, eradication, and recovery	RS.MA-01, RS.MA-02	CIS 17: Incident Response Management	A.5.24 Information security incident management planning and preparation	CC7.3, CC7.4	Partial — tabletop overdue	Incident Response Lead
Business Continuity / Disaster Recovery	Develop, document, and test plans to restore critical business functions and systems following a disruptive event	RC.RP-01, RC.RP-05	CIS 11: Data Recovery	A.5.29 Information security during disruption; A.5.30 ICT readiness for business continuity	A1.2, A1.3	Partial — see Risk R-004	Director of Infrastructure
Change Management	Require documented review and approval for changes to production systems, with defined emergency change exceptions	PR.PS-01	CIS 4: Secure Configuration Management	A.8.32 Change management	CC8.1	Partial — see Risk R-010	IT Change Manager
Secure Configuration Baselines	Establish and enforce secure configuration baselines for servers, endpoints, network devices, and cloud resources	PR.PS-01	CIS 4: Secure Configuration Management	A.8.9 Configuration management	CC6.6, CC6.8	Partial — see Risk R-008	Cloud Security Engineer
Identity Lifecycle / Deprovisioning	Ensure user access is provisioned, modified, and revoked in a timely manner tied to HR employment events	PR.AA-01	CIS 5.3: Disable Dormant Accounts	A.5.16 Identity management; A.5.18 Access rights	CC6.2, CC6.3	Partial — see Risk R-006	IAM Manager

Control Domain	Control Description	NIST CSF 2.0	CIS Controls v8	ISO/IEC 27001:2022 Annex A	SOC 2 TSC	Implementation Status	Owner
Application Security Testing	Perform static, dynamic, and/or penetration testing on internally developed and acquired applications prior to and after deployment	ID.RA-01, PR.PS-06	CIS 16: Application Software Security	A.8.28 Secure coding; A.8.29 Security testing in development and acceptance	CC8.1	Partial — see Risk R-005	AppSec Lead
Data Loss Prevention	Deploy technical controls to detect and prevent unauthorized exfiltration of sensitive data from managed endpoints and cloud services	PR.DS-01	CIS 3.13: Deploy a Data Loss Prevention Solution	A.8.12 Data leakage prevention	CC6.7	Not Implemented — see Risk R-011	Data Governance Lead
Physical Security Access Review	Periodically review physical access logs and permissions for data centers and facilities housing sensitive systems	PR.AA-06	CIS 12: Network Infrastructure Management (physical component); CIS 1	A.7.2 Physical entry; A.7.4 Physical security monitoring	CC6.4	Partial — see Risk R-009	Facilities / Security Manager
Governance & Risk Appetite	Establish and communicate a documented risk appetite and tolerance to guide risk-based decision-making	GV.RM-01, GV.RM-02	CIS Governance (cross-cutting)	A.5.1 Policies for information security; Clause 6.1 Risk assessment (ISMS)	CC1.1, CC3.1	Not Implemented	CISO
Board / Executive Reporting	Provide regular cybersecurity risk reporting to executive leadership and the board of directors	GV.OV-01, GV.OV-03	CIS Governance (cross-cutting)	Clause 9.3 Management review (ISMS)	CC1.2, CC2.1	Partial	CISO

CONTROL MAPPING — NOTES

Purpose	Demonstrates cross-framework fluency: one control implementation can satisfy multiple compliance frameworks simultaneously, avoiding duplicated effort.
Frameworks mapped	NIST CSF 2.0 (Subcategory refs) → CIS Controls v8 (Safeguard refs) → ISO/IEC 27001:2022 Annex A → SOC 2 Trust Services Criteria (Security/Availability common criteria)
Implementation Status	Implemented = control operating as designed Partial = control exists with gaps (cross-referenced to Risk Register IDs where applicable) Not Implemented = control not yet in place
How to extend	Add a row per control; a mature GRC program typically maintains 60-150+ mapped controls depending on framework scope and organization size.